

ISO 27001:2022 Architecture and the Role of Top Management

This morning, the CISO's desk built a certification business case without opening the standard. Session 3 had given its silhouette: two blocks and one principle. That was enough to decide whether to go.

Now the group is about to say yes. The silhouette is no longer enough. This lecture opens the ISO/IEC 27001:2022 standard for good: its outline, the sequence of its clauses 4 to 10, and a discovery that surprises every beginner. This standard speaks less to IT specialists than to executive management.

By the end of this lecture, the Group CISO can read the tree structure they will handle in the tool. And they can tell the Chief Executive Officer what the standard requires of her, personally.

✓ What this lecture opens, and how to read it

ISO/IEC 27001:2022: two blocks, two natures

Clauses 4 to 10: management requirements

the deciding and
checking machine: it
applies IN FULL

Annex A: 93 security controls

the concrete catalog:
it IS FILTERED by the
Statement of
Applicability

Session objectives

By the end of this lecture:

- Describe the architecture of ISO/IEC 27001:2022: the block of clauses 4 to 10, the Annex A block, and the role of each.
- Explain the logic that chains the clauses, from the context of the organization to improvement, and place each achievement of the past sessions within it.
- Define the scope of an ISMS and build it from a mapping.
- Analyze what the leadership clause requires of top management, and translate it into the governance of the MERIDIAN group.
- Place the Statement of Applicability within the architecture, rule on an Annex A control with its justification, and read a third party's certificate.

Prerequisites

- Session 3: the ISMS, the information security management system, is defined; the standard is placed among the reference frameworks; ISO/IEC 27001 requires, ISO/IEC 27002 advises. None of that is redefined here.
- The session 2 mapping: the group's business assets and supporting assets. This lecture shows that it answers a clause of the standard almost word for word.
- The risk assessment and treatment from sessions 5 and 7. The session 7 treatment plan will find its exact place in the architecture.
- This morning's certification business case, which this lecture comes to arm.

The reading method, stated openly

One point of honesty before starting, because it will also come up in a company. The ISO/IEC 27001:2022 standard is a paid document. The group will buy the official text when it launches its process, and nothing replaces that reading.

What is read today is the architecture of the standard as the GRC tool renders it. GRC stands for governance, risk and compliance: it is the family of the CISO Assistant tool used since session 3. The tool's library holds the same tree as the standard, with its titles translated. It was imported in session 3, and it is the one the lab will assess.

The titles quoted in this lecture are therefore the ones that will appear on screen. This is a reading of the structure, faithful and verifiable. It is the level a CISO needs in order to steer. The exact wording of the requirements belongs to the official text and to the auditor.

✓ A management requirements standard, reread from the top

A one-sentence reminder, since the notion has been acquired since session 3. An ISMS is a steering loop: the organization sets its security objectives, implements controls, checks that they work, then improves them. The ISO/IEC 27001:2022 standard says what this loop must contain to deserve trust. Its official title, "Requirements", sets the tone.

What session 3 had not unfolded is the nature of those requirements. The official vocabulary of the family of standards is published in ISO/IEC 27000:2018, a free document. It defines a management system as follows: "set of interrelated or interacting elements of an organization to establish policies and objectives and processes to achieve those objectives".

Three words are worth keeping from that definition: policies, objectives, processes. Not firewalls, not encryption, not antivirus. The standard therefore has two blocks, of two different natures:

- Clauses 4 to 10 bear on the machine for deciding and checking. They apply in full to whoever wants to be certified.
- Annex A carries the 93 concrete security controls, spread across 4 themes. It gets filtered: each organization keeps the controls that concern it.

The instrument of that filtering is called the Statement of Applicability. It is handled at the end of this lecture, just before moving to the tool.

This split has a consequence, which this morning's business case had already sensed: the standard is unusable without top management. Deploying an antivirus can be delegated. Management's commitment, the setting of objectives and the allocation of resources cannot. The standard requires these three things by name.

The official vocabulary defines top management as "person or group of people who directs and controls an organization at the highest level". It adds an important detail. If the management system covers only part of the organization, top management means the management of that part. This sentence carries the whole scope question discussed this morning. It will return in the concept sheet on the scope.

✓ Clauses 4 to 10: a movement already traveled

Here is the complete tree of the first block, as the tool displays it. It reads line by line. It is the skeleton of everything that follows.

Clause	Title (as displayed by the tool)	Subclauses
4	Context of the organization	4.1 Understanding the organization and its context; 4.2 Understanding the needs and expectations of interested parties; 4.3 Determining the scope of the ISMS; 4.4 Information security management system
5	Leadership	5.1 Leadership and commitment; 5.2 Policy; 5.3 Organizational roles, responsibilities and authorities
6	Planning	6.1 Actions to address risks and opportunities (including 6.1.2 Risk assessment and 6.1.3 Risk treatment); 6.2 Information security objectives and planning to achieve them; 6.3 Planning of changes
7	Support	7.1 Resources; 7.2 Competence; 7.3 Awareness; 7.4 Communication; 7.5 Documented information
8	Operation	8.1 Operational planning and control; 8.2 Risk assessment; 8.3 Risk treatment
9	Performance evaluation	9.1 Monitoring, measurement, analysis and evaluation; 9.2 Internal audit; 9.3 Management review
10	Improvement	10.1 Continual improvement; 10.2 Nonconformity and corrective action

The sequence of the clauses can be told in one sentence per clause. Together, they form a natural movement:

- Understand the terrain. Clause 4 requires knowing the organization, its context and its interested parties, then deriving the scope of the system from them.
- Commit. Clause 5 requires top management to carry the system, write its policy and distribute roles.
- Decide. Clause 6 requires planning: assess the risks, treat them, set measurable objectives.
- Equip. Clause 7 requires the means: resources, competence, awareness, communication and documents.
- Do. Clause 8 requires all of that to actually run in daily activity, risk assessments and treatments included.
- Look at oneself. Clause 9 requires measuring, auditing internally and having the whole reviewed by top management.
- Correct oneself. Clause 10 requires treating nonconformities and improving continually.



Now, the observation that changes the reading of the whole module: this movement has already been traveled. Here is the correspondence between the clauses and the eight weeks of work in the module.

Clause	What the module has already produced
4 Context of the organization	The session 2 mapping: business assets, supporting assets, DICT needs; the subsidiaries' regulatory context, sessions 1 and 3
5 Leadership	The session 1 governance: appetite set by executive management, RACI matrix, framing note
6 Planning	The risk assessment of sessions 5 and 7, the treatment plan and the register of session 7
7 Support	The GRC tool deployed, the documented deliverables, and what remains to be built in session 9: the documentary corpus
8 Operation	The implementation of the treatment plan, underway in the subsidiaries
9 Performance evaluation	The internal audit of session 4, and the indicators to be built in session 9
10 Improvement	The treatment of the audit deviations, and the cycle to be set in session 9

This table is the best argument for the defence. The group is not starting from zero. It has built, without naming it, the essentials of what the clauses require. The certification process will consist of consolidating, documenting and keeping the existing alive, not inventing everything.

It is also a warning. The weak cells of the table are the documents of clause 7 and the measurement of clause 9. That is exactly the program of session 9. The standard says where the group stands and what it lacks: that is its first use.

One precaution before going on, because the question comes up with every cohort. Diagrams circulate that present the standard as a "plan, do, check, act" wheel, the famous PDCA. It is a historical model of continual improvement, useful to convey the spirit of the loop. But it is not the structure of the 2022 edition. In a paper or before an auditor, the wheel does not map onto the clauses: the clauses are described.

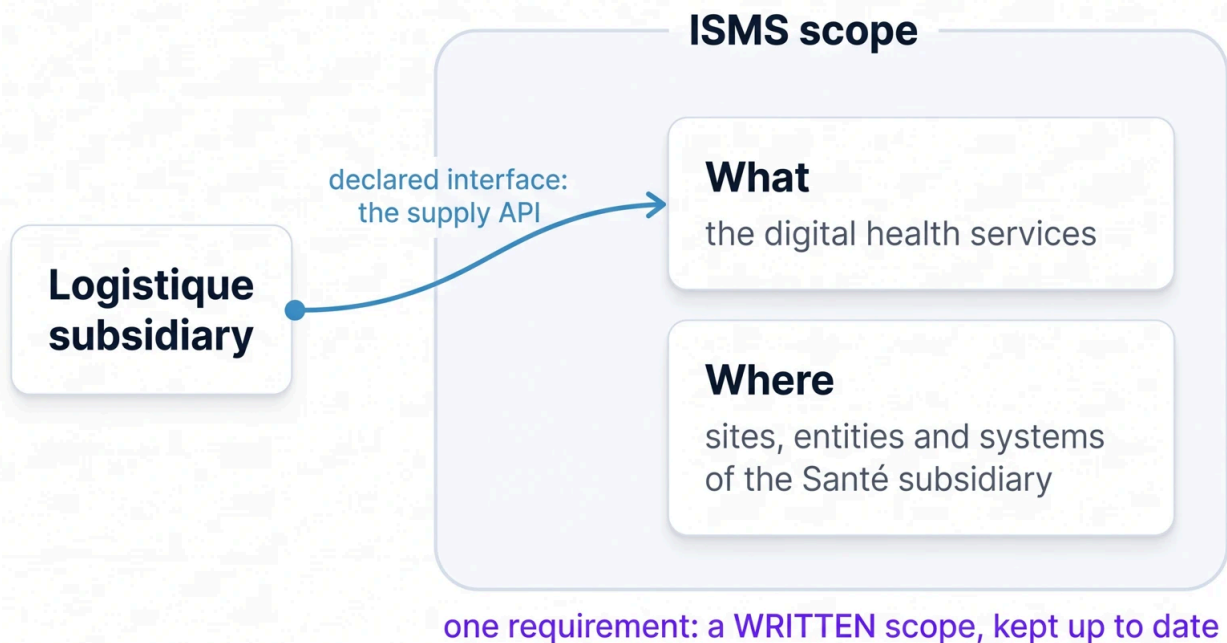
Concept sheet: the scope

The problem first. It was met this morning without being named. When the Chief Executive Officer asks "what exactly do we certify?", a written, precise and enforceable answer is needed. Without it, each stakeholder imagines a different outline, the auditor does not know what to audit, and the final certificate proves nothing.

Then the definition. The scope of the ISMS is the formal description of what the system covers: activities, sites, information systems, and interfaces with what stays outside. It is the object of subclause 4.3, "Determining the scope of the information security management system". Its position in the architecture says it all: it comes after the understanding of the context and of the interested parties. A perimeter is derived from the stakes, it is not decreed in a meeting.

The mechanics fit in three questions and one requirement:

- What: which activities and services the system protects. At MERIDIAN, for example, the digital health services of the Santé subsidiary.
- Where: which sites, which legal entities, which systems. The session 2 mapping provides this list with no extra work.
- Which interfaces: what enters and leaves the perimeter. The group's textbook case is the supply API between Logistique and Santé, a programming interface that crosses the boundary of the scope. It must therefore be declared and controlled.
- The requirement: the scope is a document, available and kept up to date. It is the first one the auditor will read.



The limit, mirror of the strength: the scope bounds the proof. Everything it excludes escapes the certificate. A scope cut too narrow produces a certificate that convinces no one. The "narrow or wide" trade-off examined this morning is exactly the trade-off of subclause 4.3. It is a management decision, not a technician's.

✓ Clause 5: what top management must do itself

Here is the political heart of the standard. Clause 5, "Leadership", holds in three subclauses. None can be executed in the CISO's office.

First subclause, "Leadership and commitment": top management must carry the system, visibly. The official vocabulary lists among the success factors of an ISMS the "visible support and commitment from all levels of management, especially top management". The important word is visible. A budget signed in silence is not enough. The organization must see that management commits, in its trade-offs, in its communications, in its reviews.

Second subclause, "Policy": top management formalizes the organization's intentions and direction on security. The official vocabulary defines a policy as the intentions and direction of an organization, as formally expressed by its top management. This document, its structure and its breakdown are the material of session 9. To keep here: top management carries the policy, not the CISO.

Third subclause, "Organizational roles, responsibilities and authorities": everyone must know what they must do and what they may decide. The session 1 RACI matrix fits here. RACI names the four roles of a responsibility: responsible, accountable, consulted, informed.



Here is the translation for MERIDIAN. It is the table to show at the defence.

What clause 5 expects	Who carries it at MERIDIAN	What already exists
Management's visible commitment	Executive management, which sets the risk appetite; the Board of Directors, which approves it	The governance set in session 1, to be made visible over time
The security policy	Executive management, on the Group CISO's proposal	The group's framework PSSI, set in session 1, to be consolidated in session 9
Roles and responsibilities	The Executive Committee, which validates the cascade; the Group CISO, who arbitrates inter-subsidiary conflicts	The session 1 RACI matrix, with its single ultimate owner
Resources and budget trade-offs	The Executive Committee	The budget envelopes arbitrated in session 1, to be connected to the security objectives

Two true stories show what "leadership" means when everything goes wrong, and what it costs when it is missing.

The first is Norsk Hydro, the Norwegian manufacturer hit by the LockerGoga ransomware in 2019. Session 1 already met it. Executive management took three decisions: refuse to pay the ransom, switch the plants to manual operation, and communicate with full transparency, day after day. No CISO could have taken them alone. Refusing to pay commits the shareholders. Going manual commits production. Communicating commits reputation. That is exactly the level of decision clause 5 wants prepared before the crisis.

The cost of the crisis remains real. One week after the attack, the Extruded Solutions division was running at only 70 to 80% of its capacity, according to the group's financial communications. Exemplary leadership does not cancel the impact. It keeps it from becoming a rout.

The second story looks at responsibility from the other end. In France, the data breach suffered by France Travail in 2024 potentially exposed the data of 43 million people. In 2026, the CNIL, the French data protection authority, fined the institution 5 million euros for failing to ensure the security of the data.

Note who is sanctioned: not a provider, not an IT department, but the organization itself, in the person of its governing bodies. It is the same philosophy as the accountable governance of NIS 2, seen in session 3. Law and standard alike push the responsibility for security up to the top. Presenting clause 5 to management is not asking it for a favor for security. It is showing it the seat that is already its own.

And it is a seat that executive teams occupy better and better, if the profession's barometers are to be believed:



The last line deserves a future CISO's reflection. In 2024, according to the barometer of CESIN, the club of security officers of large French companies, 20% of cybersecurity leaders reported directly to executive management. The reporting line is not an org chart detail. It determines whether security's voice reaches the level where clause 5 places responsibility. At MERIDIAN, the question has been settled since session 1: the Group CISO reports to the top. In a job interview, it is one of the first questions to ask.

✓ **Clauses 9 and 10: the loop closes, and session 9 announces itself**

Only a word on the last two clauses. Their implementation is the material of the next session.

Clause 9, "Performance evaluation", requires three things: monitoring and measuring the system, auditing it internally, and having it periodically reviewed by top management. The group already experienced the internal audit in session 4.

Clause 10, "Improvement", requires treating each nonconformity with a corrective action, and improving the system continually.

Together, these two clauses turn the ISMS into a loop. One does not build a compliant system, one builds a system that corrects itself. Session 9 will equip that loop with indicators, dashboards and an improvement cycle. To keep until then: certification does not reward perfection, it checks that the loop turns.

✓ **The takeaways, and the door left open**

Three takeaways, and one open door.

- First takeaway: ISO/IEC 27001:2022 is a management requirements standard. Two blocks: clauses 4 to 10, which apply in full, and Annex A, which gets filtered.
- Second takeaway: the clauses tell a movement, understand, commit, decide, equip, do, measure oneself, correct oneself. The module has already had that movement traveled, which makes the group a credible candidate.
- Third takeaway: clause 5 puts top management before its own obligations, visible commitment, policy, roles. The session 1 governance already answers them in large part.

The open door is the Annex A filter. How does one go from 93 generic controls to the MERIDIAN group's controls? Who decides that a control does not apply, and before whom must it be justified? That is the Statement of Applicability, the object of the last part of this lecture. It is also the document the session 7 treatment plan was waiting for.

✓ The Annex A filter and proof by a third party

Two notions to finish. The Statement of Applicability, which the lab will translate into the tool control by control. And the certification process, which the morning's business case sensed without naming it. The full-day version of the session keeps the tutorial that carried them; the essentials are here.

The Statement of Applicability

The problem first. Annex A offers 93 generic controls, written for every organization in the world. No real organization implements them as they are, nor all to the same degree. A document is therefore needed that says, control by control, what the organization does with them, and why.

Then the definition. The Statement of Applicability is that document. Professionals shorten it to SoA. It is the complete list of Annex A controls, where each receives three things: a status, applicable or not; a justification; a pointer to its implementation. The official vocabulary ISO/IEC 27000:2018 puts it this way: "The selection and implementation of controls should be documented within a statement of applicability to assist with compliance requirements". The same text recognizes that a control may not apply everywhere: "It is necessary to recognize the possibility that some controls not be applicable to every information system or environment, and not be practicable for all organizations."



The mechanics lie in a linkage students most often miss. The Statement of Applicability does not come out of nowhere: it comes out of risk treatment. In the tree above, subclause 6.1.3 is titled "Information security risk treatment". That is where the Statement of Applicability lives. The complete chain:

- The session 7 register rated risks and settled treatment options.
- Each risk the group decided to reduce calls for controls. Those controls are found in Annex A and are declared applicable, justified by that risk.
- Added to them are the controls a law or a contract imposes, justified by that requirement.
- Whatever corresponds neither to a treated risk, nor to an obligation, nor to a reality of the group can be declared not applicable, with a justification that will hold before an auditor.

The limit, to be said to management as well: a Statement of Applicability measures nothing, it declares. The real implementation percentage will come from the assessment, the one conducted in the lab.

💡 Three possible justifications for an applicable control: a risk from the register, a legal requirement, a contractual requirement. A single family of justifications for a non-applicable control: the group's reality, never its comfort. "Too expensive" is not an exclusion, it is an accepted risk, and it is dealt with in the session 7 register, not in the Statement of Applicability.

Worked example: eight controls for MERIDIAN

To set the level of demand of a justification, here are eight Annex A controls, with the titles the tool displays. They are to be ruled on for the scope of the subsidiary under review discussed this morning, with its interfaces toward the other subsidiaries (\$6 of the subsidiary pack). For each, three things to produce:

- a status: applicable or not applicable;
- a one-sentence justification, attached to a piece of the file: a risk from the session 7 register, an audit deviation from session 4, a legal or contractual requirement, or a reality of the scope;
- for the applicable controls, the presumed current state in the subsidiary under review, in one word: in place, partial, absent.

The directives of the framework policy, the information security policy codified in session 1 (ACC-01 to COR-01), are authoritative. One of the eight controls requires investigation before decision: spot it before reading on.

Control	Displayed title
A.5.9	Inventory of information and other associated assets
A.5.17	Authentication information
A.5.19	Information security in supplier relationships
A.5.24	Information security incident management planning and preparation
A.6.3	Information security awareness, education and training
A.7.4	Physical security monitoring
A.8.8	Management of technical vulnerabilities
A.8.28	Secure coding

The expected reading, control by control:

- A.5.9, Inventory of information and other associated assets: applicable. Justification: the requirement to know the information system, which underpins the whole approach. State partial: the session 2 mapping is that inventory, but the holes found in session 2 remain open. It is the best-served control in the file, and it is not complete.
- A.5.17, Authentication information: applicable. Justification: the authentication deviation of the subsidiary under review found in session 4, shared accounts or passwords without multifactor authentication (\$5 of the subsidiary pack), and directive ACC-01. State partial: the session 7 treatment plan carries the remediation.
- A.5.19, Information security in supplier relationships: applicable. Justification: the third-party risks examined in session 6, with as supporting piece the third party with shared access of the subsidiary under review, or its critical third party depending on the pack (\$3 and \$6). State partial: the session 6 third-party requirements exist, but their contractual rollout is beginning.

- A.5.24, Information security incident management planning and preparation: applicable. Justification: directive INC-01, notification of any major incident to the Group CISO within two hours, and the unavailability scenario of the subsidiary under review in the register. State partial at best: session 9 will equip the response.
- A.6.3, Awareness: applicable. Justification: the awareness key risk indicator (KRI) the group's dashboard has carried since session 1. State partial.
- A.7.4, Physical security monitoring: applicable. Justification: the reality of the sites of the subsidiary under review (§2 and §4 of the subsidiary pack). State to be investigated site by site.
- A.8.8, Management of technical vulnerabilities: applicable. Justification: directive COR-01, critical patches within 14 days, and the updates carried out by third parties on the systems of the subsidiary under review, without validation or prior notice depending on the pack (§3 and §4). State partial: the systems obsolescence indicator will bear witness to it in session 9.
- A.8.28, Secure coding: this is the control that requires investigation before decision, and the answer depends on the pack.

For A.8.28, the reasoning is as follows. If the chosen scope includes no internal software development, the control can be declared not applicable, with as justification the absence of development activity in the scope. But it has to be checked:

- Santé and Logistique: the services are operated on third-party software packages, the vendor's HIS (hospital information system) and the WMS (warehouse management system) maintained by the TPAM provider (third-party application maintenance), with no developer named in the pack. The question goes to the subsidiary CISO or to the IT manager: "does the scope contain internal application development, yes or no?".
- Territoires: the citizen services platform runs on "one instance per local authority, same code" (§4), and the pack does not say who writes that code. Same question, to the cluster IT Director, who operates the platform, and to the subsidiary's IT manager.
- Éducation: the pack settles it. The portal is developed in-house by about twenty developers (§2), and the secure development rules live in pinned messages of a chat channel (§5). The control is therefore applicable and noncompliant. The control to investigate is then elsewhere: A.7.4, the server room of the cluster head office (§4) which nobody says who monitors, or A.5.24, Legal being unable to say whether the absence of notification comes from the absence of incidents (§3).

Ruling without investigating would be exactly the kind of comfort exclusion an auditor overturns.

The general rule this example applies: an admissible justification is traced. It points to an object that exists: a rated risk in the register, a dated audit deviation, a legal text, a contract clause, a verifiable reality of the scope. An inadmissible justification is declarative: it invokes common sense, cost or habit. The test: a third party opening the file must be able to verify the justification without taking the writer's word for it.

Certification: a third-party audit, and a chain of trust

The certification process, with its exact vocabulary. An audit is, in the terms of the official vocabulary, a "systematic, independent and documented process for obtaining audit evidence and evaluating it objectively to

determine the extent to which the audit criteria are fulfilled". The word that founds everything is independent.

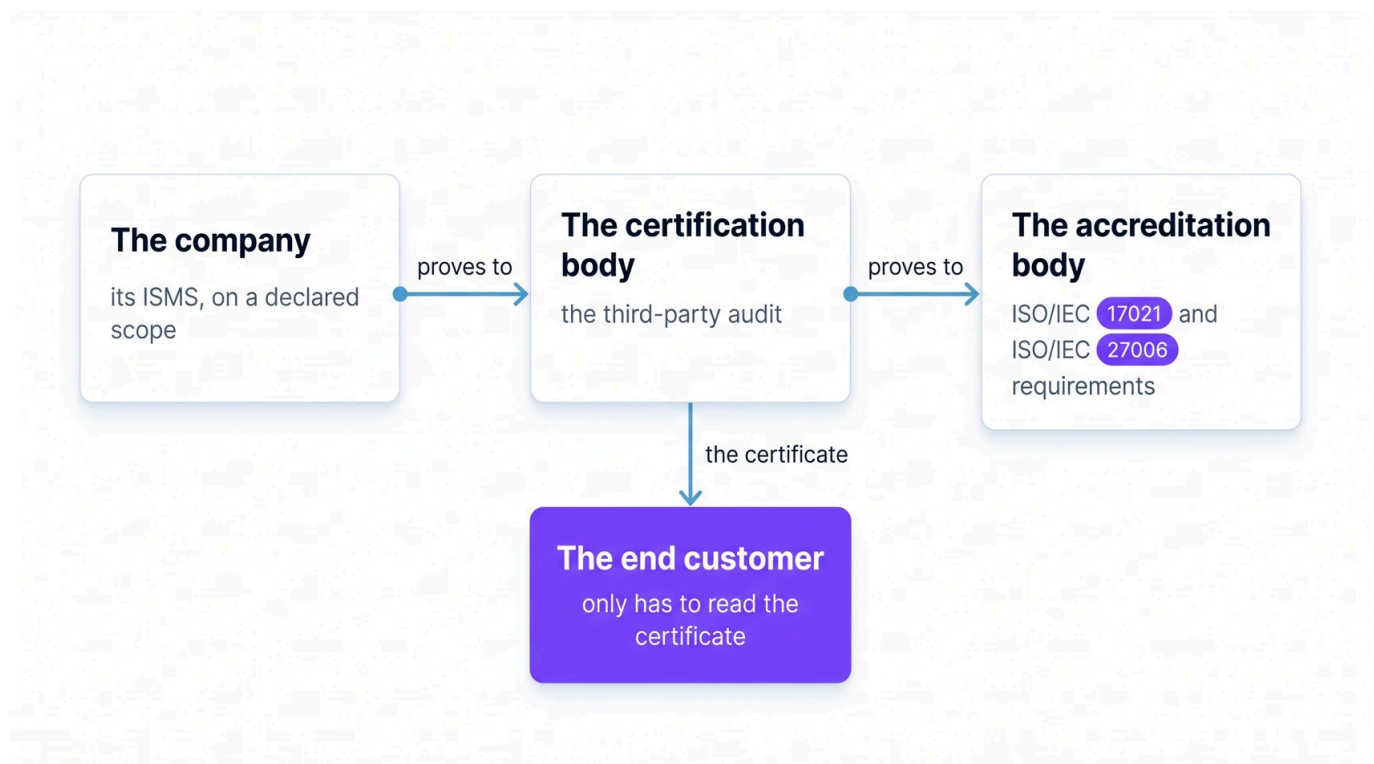
The same vocabulary distinguishes three parties:

- the internal audit, called first-party, the one the group conducted in session 4;
- the second-party audit, conducted by a client on its supplier;
- the third-party audit, conducted by a body that is neither the organization nor its client.

Certification is the culmination of a third-party audit. A certification body audits the ISMS against the requirements of the standard, on the declared scope, and issues the certificate or not.

Every management then asks the question: "who guarantees us this body's seriousness?". The answer holds in two references. Certification bodies are themselves evaluated and accredited, against ISO/IEC 17021, supplemented by ISO/IEC 27006. The latter exists precisely, says its introductory text, to support the accreditation of bodies certifying against ISO/IEC 27001.

It is a chain of trust with three links: the company proves to the auditor, the auditor proves to the accreditor, and the end client only has to read the certificate.



What this lecture does not detail, for lack of a source consultable in session: the exact cadence of certificate maintenance audits, set by the accreditation standards. Only this to keep: a certificate is maintained, it is not obtained once and for all.

Reading a third party's certificate

The Statement of Applicability also serves in the other direction: when a third party presents its certificate.

Example: the group is evaluating two providers for a need of the subsidiary under review opened in session 6, hosting, backup, maintenance or monitoring. Each attaches an ISO/IEC 27001 certificate to its offer.

- Provider A presents a certificate covering "the ISMS of the software development activities of the Nantes site", issued two years ago by an accredited certification body.
- Provider B presents a certificate covering "the ISMS of infrastructure operation and monitoring services on behalf of clients", issued six months ago by a body whose accreditation appears on no known register.

What does each prove, what does it not prove, and what should be written on the "certification" line of the bid evaluation grid?

Provider A: the certificate is authentic and its issuer accredited. But its scope, the software development of one site, does not cover the service the group is buying, an operation or monitoring service. It proves a security management culture somewhere at this supplier. It proves nothing about the activity that will touch the assets of the subsidiary under review. Follow-up request: is the exact scope of their operation services covered by an ISMS, certified or not, and can they provide their Statement of Applicability on that scope?

Provider B: the scope matches the need and the date is fresh. But the value of the certificate rests entirely on the accreditation chain, and here it is unverified. A certificate issued by a non-accredited body is an assertion, not a proof. Follow-up request: the reference of the certifying body's accreditation, verifiable on the accreditor's register.

Verdicts for the grid: A, certificate outside the scope, not taken into account as it stands, contractual guarantees to be required in compensation. B, certificate relevant subject to verification of the accreditation, file suspended on that verification. In both cases, the session 6 lesson applies: the label never replaces the security assurance plan and the contract clauses, it complements them.

What to carry into the tool: three questions per control. Which piece justifies it? What is its real state? If it is excluded, which verifiable fact makes it moot? The lab asks them on fifteen controls before lunch. The afternoon's supervised project time makes it possible to go through all 93.